

Mecanismos de Gestão Dinâmica de Confiança (Trust Management) para Controle de Acesso Contextual em Microserviços

André Cota Guimarães

Engenharia de Software – PUC Minas

Orientadores: Glender Brás de Medeiros e Leonardo Vilela Cardoso

September, 2026

1. Área, Problema de Pesquisa e Justificativa

Área e Contexto

Engenharia de Software / Arquitetura Distribuída: Controle de acesso contextual e segurança *Zero Trust* em microsserviços nativos da nuvem (*Cloud-Native*/Kubernetes).

Problema de Pesquisa

- Perímetro aberto e confiança implícita pós-autenticação inicial no API Gateway.
- Risco de **movimentação lateral** caso um contêiner ou token seja comprometido.
- Ausência de reavaliação contínua do risco/confiança da requisição em *runtime*.

Justificativa e Relevância

- Alinhamento com a arquitetura **Zero Trust** (NIST SP 800-207): "*Nunca confiar, sempre verificar*".
- Uso de **Policy-as-Code** para tornar a governança de acesso automatizada e auditável.
- Redução direta do raio de exposição (*blast radius*) de ataques em nuvem.

2. Objetivos do Trabalho

Objetivo Geral

Propor, implementar e avaliar um mecanismo de **Gestão Dinâmica de Confiança** (*Trust Management Framework*) baseado em **Policy-as-Code** para controle de acesso contextual em tempo de execução (*runtime*) em arquiteturas de microsserviços.

Objetivos Específicos

- 1 **Mapear e formalizar** atributos contextuais de risco (frequência de chamadas, contexto de IAM, histórico) para cálculo do *Trust Score*.
- 2 **Desenvolver um protótipo** do motor de confiança (*Trust Engine*) integrado ao **Open Policy Agent (OPA)** e a um API Gateway.
- 3 **Realizar um estudo experimental** em cluster Kubernetes comparando a taxa de mitigação de requisições anômalas e o *overhead* de latência gerado.

3. Trabalhos Relacionados

1. Khatibi et al. (2025) – *Securing Cloud-Native Applications via IaC and DevOps*

- **Contribuição:** Aplicou defesa em profundidade (4C) em Amazon EKS utilizando Terraform, Snyk, Trivy e Istio mTLS.
- **Lacuna para este TCC:** Embora garanta mTLS na rede, o estudo aponta expressamente que a **Gestão de Confiança (Trust Management)** é o passo futuro necessário para impedir requisições anômalas entre pods autenticados.

2. Future Internet / MDPI (2025) – *A Unified RBAC and ABAC Risk-Aware Access Control Approach*

- **Contribuição:** Propôs modelos de controle de acesso baseados na avaliação contínua de atributos contextuais e pontuação de risco (*Risk/Trust Score*).
- **Diferencial deste TCC:** Aplicar essa avaliação de confiança em tempo de execução para microsserviços através de regras declarativas de **Policy-as-Code (OPA/Rego)** em ambiente Kubernetes.

4. Materiais e Métodos

Materiais & Ferramentas

- **Orquestrador:** Kubernetes (EKS/Minikube)
- **Engine:** OPA (Rego)
- **Contexto:** Redis
- **Carga:** k6 / JMeter
- **IaC:** Terraform / Docker

Fluxo Metodológico da Pesquisa

